

BiTorus

Agentic Threat Intelligence and Collective Defense Comprehensive Business, Product, Architecture, and Delivery Plan

Comprehensive Business & Technical Plan | Version 4.4 | August 9, 2026

Design thesis. BiTorus is an independent threat-intelligence and collective-defense network for autonomous systems. It reconstructs causal attack flows, discovers emerging agentic threat patterns, identifies affected models, frameworks, tools and configurations, and distributes portable signed detections, regression tests, and mitigations. Enterprise enforcement systems are integration surfaces; the compounding asset is the intelligence corpus and trusted network.

This document adapts the BiTorus 2.0 comprehensive design to reflect the modern threat-intelligence ecosystem and the security requirements of AI applications, tool-using agents, retrieval systems, persistent memory, model supply chains, and AI-enabled adversaries.

Table of contents

- Executive summary
- 1. Why the plan must change
- 2. Revised product thesis
- 3. Scope, non-goals, and launch wedge
- 4. Modern threat-intelligence model
- 5. AI threat taxonomy
- 6. Reference architecture
- 7. AI execution trace and data model
- 8. Threat assertions and lifecycle
- 9. Identity, capabilities, and authorization
- 10. Detection, correlation, and intelligence graph
- 11. AI supply-chain and release security
- 12. Privacy-preserving federation
- 13. Response architecture and safety
- 14. Cryptographic architecture
- 14.1 Compromise-resilient network security architecture
- 15. Platform implementation
- 16. Product surfaces and integrations
- 17. Reliability, support, and incident operations
- 18. Security assurance and evaluation
- 19. Adapted roadmap
- 20. First 90 days
- 21. Team and operating model
- 22. Success metrics
- 23. Risk register
- 24. Architecture decisions
- Appendix A. Example AI threat assertion
- Appendix B. Example capability policy
- Appendix C. Initial engineering epics
- References

Executive summary

The original BiTorus concept centered on rapid propagation of security observations, collective corroboration, immutable provenance, automated quarantine, and privacy-preserving collaboration. Those objectives remain valuable. The implementation must now account for two major changes: cyber threat intelligence has shifted from indicator feeds toward behavioral, sequence-aware, operational intelligence; and AI systems introduce new instruction, memory, tool, and supply-chain attack surfaces.

A useful analogy is a distributed ocean early-warning network. Tsunami buoys, seafloor pressure sensors, seismic stations, and undersea acoustic sensors do not depend on any single sensor being perfect: individual sensors may fail, be noisy, or even be compromised, while geographically and technically independent observations are correlated into a higher-confidence warning. BiTorus should work the same way. Each participating environment is a local sensor with its own keys and policy authority; a novel agentic attack can be converted into a privacy-minimized Agentic Threat Pattern, corroborated across independent sources, and distributed as signed detections, regression tests, and mitigations before the same attack reaches other participants.

The network must be designed on the assumption that some BiTorus services, customer sensors, federation participants, or signing keys will eventually be compromised. A successful intrusion must therefore be survivable: no central BiTorus service receives universal authority over customer environments, no tenant can impersonate another, online intelligence keys cannot replace offline trust roots, global conclusions require independent corroboration, and customers continue operating safely when the federation is unavailable or distrusted.

- Retain local-first sensing and response. Raw telemetry remains inside the customer trust domain by default.
- Share signed, privacy-minimized assertions about behavior, attack sequences, affected systems, and evidence commitments.
- Use ATT&CK for conventional adversary behavior and ATLAS for attacks involving AI-enabled systems.
- Instrument the full AI execution chain: input provenance, retrieval, prompt construction, model invocation, tool proposal, policy decision, execution, result, and memory mutation.
- Place deterministic authorization outside the model. Models may propose actions; a capability broker decides whether execution is permitted.
- Treat models, prompts, adapters, tool schemas, policies, evaluation suites, and retrieval configurations as signed release artifacts.
- Use a Merkle transparency log for provenance and equivocation detection, not a blockchain data plane.
- Separate enterprise federation from public research participation and community sensors.
- Launch with a Kubernetes- and cloud-native agent-security product: observability, capability control, threat detection, and federated intelligence for tool-using AI agents.

The adapted plan adds an AI Security Plane to BiTorus 2.0. It does not replace the core cyber-defense platform. It extends the same identity, signing, provenance, privacy, and response mechanisms to AI-native entities and execution traces.

1. Why the plan must change

1.1 Threat intelligence has become behavioral and operational

High-volume lists of IP addresses, domains, hashes, and CVEs remain useful but decay quickly and often lack context. Modern defenders increasingly need adversary behavior, attack sequences, identity activity, cloud control-plane actions, software supply-chain context, detection logic, response playbooks, and evidence quality.

Earlier CTI pattern	Modern requirement	BiTorus adaptation
Atomic indicators	Behavior and sequences	ATT&CK/ATLAS mappings plus attack-flow graph
Static feed entries	Versioned operational packages	Assertions, rules, hunts, mitigations, tests, and revocations
CVE severity	Exploit and exposure context	KEV, EPSS, reachability, runtime evidence, and asset criticality
Trust by publisher name	Cryptographic provenance and calibrated quality	Signed evidence, source history, independence, and confidence
Human-readable reports	Machine-actionable defense	Typed schemas, policy packages, OpenC2/CACAO-compatible response objects

1.2 AI changes the trust boundary

In AI applications, untrusted content can be interpreted as instructions. Tool-using agents can convert a model error, prompt injection, poisoned retrieval result, or malicious memory entry into real side effects. The security boundary therefore cannot be the model prompt or system message. It must be an external policy and capability layer.

- Natural-language instructions and data share the same channel.
- A retrieved webpage, email, issue, document, or tool result may contain adversarial instructions.
- Agents may have durable memory and may delegate to other agents.
- Model output is nondeterministic and can be persuasive without being correct.
- Provider-side and model-version changes can alter behavior without application code changes.
- AI systems add model, adapter, prompt, dataset, evaluation, retrieval, and tool supply chains.
- AI lowers the marginal cost of reconnaissance, scripting, personalization, and multi-step operation for attackers.

2. Revised product thesis

Design thesis. BiTorus is an independent threat-intelligence and collective-defense network for autonomous systems. It reconstructs causal attack flows, discovers emerging agentic threat patterns, identifies affected models, frameworks, tools and configurations, and distributes portable signed

detections, regression tests, and mitigations. Enterprise enforcement systems are integration surfaces; the compounding asset is the intelligence corpus and trusted network.

2.1 Product pillars

Pillar	Capability	Customer outcome
Execution provenance	Causal trace from input through side effect	Explain what happened and prove which policy authorized it
Capability enforcement	Short-lived, typed, task-bound permissions	Prevent excessive agency and reduce credential blast radius
Threat intelligence	ATT&CK + ATLAS assertions and attack flows	Recognize campaigns and AI-specific abuse across organizations
Secure distribution	Signed rules, policies, prompts, models, and evaluations	Prevent rollback, freeze, and supply-chain substitution
Federated privacy	Minimized assertions, commitments, PSI, and secure aggregation	Share defensive value without centralizing raw data
Safe response	Local authorization, reversible actions, approvals, and rollback	Automate without surrendering control

2.2 Initial product wedge

The recommended first product is an observability, authorization, and threat-intelligence layer for enterprise AI agents that operate in Kubernetes and cloud environments. It should integrate with existing model gateways, agent frameworks, MCP servers, CI/CD systems, source repositories, cloud APIs, and Kubernetes controllers.

- Proxy or instrument model, retrieval, memory, and tool interactions.
- Normalize a causal execution trace.
- Issue and validate narrow capabilities for tool execution.
- Detect prompt injection, tool abuse, secret exfiltration, memory poisoning, and cross-tenant access attempts.
- Map incidents to ATT&CK and ATLAS.
- Generate signed, privacy-minimized threat assertions.
- Distribute signed policy updates and evaluation cases.
- Apply locally authorized reversible controls.

3. Scope, non-goals, and launch wedge

3.1 Launch scope

- Kubernetes workloads and cloud control planes.
- AI applications using model APIs or self-hosted models.
- Tool-using agents, including MCP-style tool systems.
- Retrieval-augmented generation and persistent agent memory.

- Identity, repository, CI/CD, container-image, and secret-access telemetry.
- Signed AI and cyber threat assertions.
- Capability-based tool authorization.
- Reversible workload, identity, and network response.

3.2 Explicit non-goals

- A universal model firewall that claims to solve prompt injection through content filtering alone.
- Granting models direct production credentials.
- Autonomous destructive remediation.
- A public permissionless federation.
- Central collection of raw prompts, customer documents, or complete conversations by default.
- Training a global foundation model on customer telemetry.
- Replacing EDR, SIEM, CSPM, identity providers, or model gateways.
- Attribution of campaigns solely from LLM-generated interpretation.

4. Modern threat-intelligence model

4.1 Intelligence package

BiTorus should treat intelligence as a package whose components can be independently accepted, rejected, updated, or revoked.

- Threat Intelligence Package
- observation and evidence commitments
 - behavioral interpretation
 - ATT&CK and/or ATLAS mappings
 - attack-flow fragment
 - affected assets, models, tools, and configurations
 - detection rule
 - hunt query
 - mitigation or response recommendation
 - validation test
 - confidence, sharing policy, expiry, and revocation metadata
 - signatures and transparency inclusion proof

4.2 Observation, inference, verdict, and action

Layer	Meaning	Authority
Observation	A sensor records an event or state	Sensor and evidence signature
Inference	A rule, model, or analyst interprets observations	Named detector/model version
Verdict	A tenant or federation classifies the case	Explicit policy and review path
Recommendation	A defensive response is proposed	Signed playbook or analyst decision
Authorization	Local policy permits a specific action	Tenant-controlled policy engine
Execution	An actuator performs and records the action	Execution receipt and rollback state

4.3 Vulnerability intelligence

Vulnerability prioritization should combine technical severity with known exploitation, exploitation probability, exposure, reachability, runtime evidence, asset criticality, and compensating controls. No single score should directly trigger quarantine.

5. AI threat taxonomy

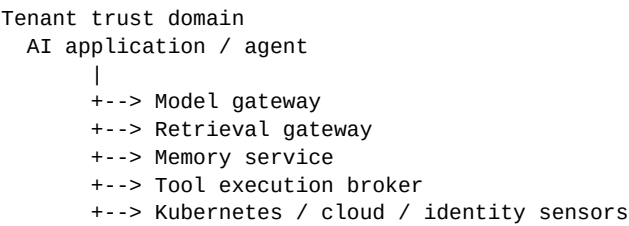
5.1 AI-enabled conventional threats

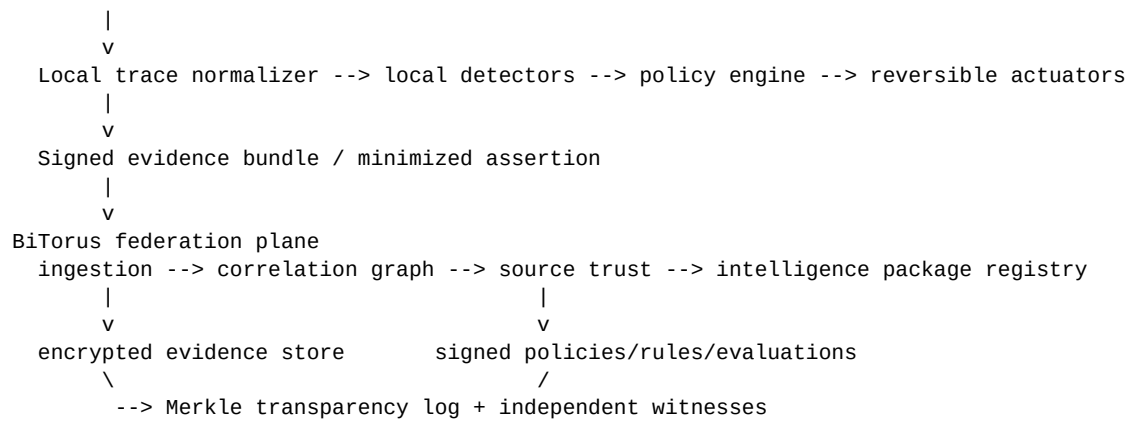
- Accelerated reconnaissance and target profiling.
- Code generation and exploit adaptation.
- Credential phishing and social engineering at scale.
- Automated data triage and exfiltration planning.
- Multi-agent orchestration of conventional attack steps.

5.2 Threats against AI systems

Threat class	Examples	Primary controls
Instruction attacks	Direct/indirect prompt injection, jailbreaks, tool-result injection	Content provenance, instruction hierarchy, external authorization
Agency abuse	Overbroad tools, recursive delegation, unsafe side effects	Capabilities, approvals, sandboxing, rate limits
Data and retrieval attacks	Poisoned corpus, malicious documents, vector-store manipulation	Source trust, signing, retrieval lineage, quarantine
Memory attacks	Persistent malicious facts or instructions	Versioned memory, namespace isolation, approval, TTL, rollback
Model attacks	Extraction, evasion, unsafe model/version behavior	Gateway telemetry, model-specific evaluations, version binding
Supply-chain attacks	Compromised model, adapter, tokenizer, MCP server, prompt package	Signed releases, AI-BOM, transparency, TUF
Resource abuse	Denial of wallet, looped agents, tool storms	Budgets, step limits, circuit breakers, anomaly detection
Confidentiality failures	Secrets in context or output, cross-tenant retrieval	Data policy, redaction, tenant isolation, DLP

6. Reference architecture





6.1 AI Security Plane

- Model gateway records model identity, version, policy digest, and request lineage.
- Retrieval gateway records source identifiers, trust labels, retrieval scores, and content digests.
- Memory service records reads, writes, source provenance, confidence, namespace, TTL, and rollback history.
- Tool broker validates typed arguments, capabilities, policy, risk class, approval requirements, and execution environment.
- Trace normalizer produces a causally linked event graph rather than isolated logs.

6.2 Federation Plane

- Receives only tenant-authorized minimized assertions.
- Evaluates source history, evidence quality, and independence.
- Builds campaign and attack-flow correlations.
- Distributes signed rules, policies, evaluations, and mitigations.
- Records hashes, signatures, revocations, and checkpoints in a transparency log.

7. AI execution trace and data model

7.1 Required trace events

- session creation and user/service identity
- model selection and exact version
- system policy and prompt-template digests
- input origin and trust classification
- retrieved document identifiers and content digests
- prompt construction lineage
- model request and response commitment
- structured action proposal
- tool name, typed arguments, and requested capability
- policy decision and approval
- actual execution and sandbox identity
- tool result and external side effects
- memory reads and writes
- delegation to another agent

- final response and incident linkage

7.2 Core entities

Entity	Key attributes
ModelVersion	provider, model, digest, release, capabilities, evaluation state
Agent	owner, code digest, prompt digest, tool set, policy binding
InferenceSession	tenant, requester, purpose, budget, trace root
RetrievedDocument	source, signer, trust, digest, retrieved_at
Tool	schema, owner, risk class, execution backend
Capability	subject, action, resource, constraints, expiry
MemoryEntry	namespace, source, confidence, TTL, approval, history
PolicyDecision	policy version, inputs, decision, obligations
ExecutionReceipt	capability, sandbox, side effects, result, rollback

8. Threat assertions and lifecycle

8.1 Assertion lifecycle

publish -> corroborate -> challenge -> correct -> supersede -> retract -> expire -> archive

8.2 Privacy and binding

- Bind AI assertions to exact model, prompt, tool, policy, and retrieval configuration where relevant.
- Use short default lifetimes because provider and configuration changes can alter behavior.
- Do not share raw prompts or complete traces by default.
- Share digests, structured behavior, minimized reproductions, and tenant-controlled evidence disclosures.
- Retain retractions and corrections in the transparency history while removing them from active operational state.

9. Identity, capabilities, and authorization

9.1 Capability model

An agent should not inherit the full authority of a user or service. It should receive a task-specific, short-lived capability that names the allowed action, target, constraints, and expiry.

```
allow:
  subject: agent://tenant-a/code-reviewer/session-7
  action: create_pull_request
  resource: github://org/repo
  constraints:
    branch_prefix: bitorus/
    max_files_changed: 25
    deny_paths: [.github/workflows, infra/prod]
    expires_at: 2026-08-04T18:00:00Z
    human_approval: required_if_sensitive_path
```

9.2 Deterministic security boundaries

- Retrieved content cannot authorize a tool call.
- Model output cannot change governing policy.
- An agent cannot grant itself new capabilities.
- Secrets enter model context only through explicit data policy.
- High-risk operations require approval or an independently signed playbook.
- Capabilities are revocable and bound to tenant, task, session, and execution identity.
- All denied and allowed actions generate policy receipts.

10. Detection, correlation, and intelligence graph

10.1 Dual ontology

Use ATT&CK for conventional adversary behavior and ATLAS for attacks against AI-enabled systems. One incident may traverse both.

```
Poisoned document retrieved [ATLAS]
-> indirect instruction overrides agent goal [ATLAS]
-> credential-discovery tool requested [ATT&CK]
-> cloud credential read [ATT&CK]
-> persistence resource created [ATT&CK]
```

10.2 Graph edges

PRECEDES, CAUSED_BY, RETRIEVED_FROM, INSTRUCTED, PROPOSED_ACTION, AUTHORIZED_BY, EXECUTED_AS, USED_CREDENTIAL, WROTE_MEMORY, CORROBORATES, CONTRADICTS, SUPERSEDES, MITIGATED_BY, and AFFECTS.

10.3 Detector layers

- Deterministic protocol and policy violations.
- Known malicious indicators and package intelligence.
- Behavioral rules across tool and identity sequences.
- Graph and temporal correlation.
- Tenant-specific anomaly detection.
- Model-assisted interpretation with evidence references.
- Cross-tenant campaign correlation over minimized assertions.

11. AI supply-chain and release security

11.1 AI bill of materials

- base model and exact version or digest
- provider endpoint and routing policy
- adapters, fine-tunes, and quantization
- tokenizer and embedding model
- prompt templates and system policies
- retrieval corpora and connectors
- agent framework and orchestration code

- tools, plugins, and MCP servers
- evaluation suites and threat corpus
- guardrails, classifiers, and policy versions

11.2 Signed release bundle

Every production release should state what changed, who approved it, which evaluations passed, what capabilities were added, which data may be accessed, and which rollback artifact is available.

- Generate provenance and an AI-BOM.
- Sign artifacts with role-separated keys.
- Publish transparency-log inclusion.
- Use TUF metadata for rollback, freeze, and mix-and-match resistance.
- Deploy through rings with automatic rollback thresholds.
- Retain exact evaluation evidence for each release.

12. Privacy-preserving federation

- Full traces stay tenant-local by default.
- Federation receives structured assertions, hashes, selected features, and encrypted evidence references.
- Private set intersection may be used for matching sensitive indicators or poisoned-document digests.
- Secure aggregation may be used for fleet-wide prevalence or evaluation statistics.
- MPC or FHE is introduced only for a benchmarked, high-value query that cannot be solved through minimization.
- Evidence disclosure is policy-driven, logged, and scoped to a challenge or incident.

13. Response architecture and safety

Risk class	Examples	Default decision
Observe	Increase tracing, collect evidence, run evaluation	Automatic
Constrain	Reduce tool scope, block domain, disable memory write	Automatic at high confidence
Isolate	Quarantine workload, revoke one session, remove tool	Policy or approval
Modify	Create PR, change nonproduction config	Typed policy and review
Destructive	Delete data, broad credential revocation, production change	Explicit human approval
Emergency	Freeze releases, revoke root, disable federation	Multi-party administrative approval

- All automated actions are idempotent, time-bounded, observable, and reversible where possible.
- The policy engine evaluates actual tool arguments, not only model intent.
- The execution broker uses a constrained environment and short-lived credentials.
- The model receives execution results but cannot alter receipts.
- A global kill switch and tenant-local kill switch are mandatory.

14. Cryptographic architecture

Purpose	Design
Transport	TLS 1.3 mutual authentication; standardized hybrid/PQ modes only where supported
Workload identity	Short-lived workload identities backed by attestation
Assertions	Deterministic encoding and context-bound signatures
Artifact distribution	TUF metadata plus signed artifacts and transparency proofs
Evidence storage	Per-tenant envelope encryption with KMS/HSM protected keys
Long-lived artifacts	Dual-sign classical and ML-DSA where operationally justified
Key establishment	ML-KEM through standardized protocol integrations; avoid custom cryptographic constructions
Crypto inventory	Algorithm, parameter, owner, purpose, expiry, dependency, and migration state

Cryptographic agility remains mandatory. Identity must not be permanently bound to one algorithm or key. Verification must support controlled overlap, revocation, and migration.

14.1 Compromise-resilient network security architecture

BiTorus should not be secured as a single trusted central service. It should be engineered as a compromise-resilient federation in which each trust domain has narrowly scoped authority, decision-bearing artifacts are cryptographically authenticated, and local customer policy remains the final authority for consequential actions. The objective is not to claim that compromise is impossible; it is to prevent any single compromise from silently becoming global control.

14.1.1 Non-negotiable security invariants

- Compromise of BiTorus SaaS cannot directly execute arbitrary actions inside a customer environment.
- Compromise of one tenant or federation participant cannot impersonate another tenant or create global truth by itself.
- Compromise of an online intelligence-signing key cannot replace the offline trust root or software-release authority.
- Externally supplied intelligence cannot directly authorize destructive or broad-impact actions; local tenant policy remains authoritative.
- Customers can continue operating safely when BiTorus is offline, partitioned, or temporarily distrusted.

14.1.2 Separate intelligence from execution authority

BiTorus publishes observations, confidence, exposure assessments, detections, regression tests, and proposed mitigations. A customer-side verifier and policy engine decides whether a mitigation is

accepted, simulated, staged, approved, or rejected. There must be no universal command channel from the federation into customer production systems.

Intelligence class	Default effect	Required local control
Informational	Alert, enrich, or hunt	Automatic consumption may be allowed
Detection	Install or activate a local detector	Signature + policy verification
Reversible restriction	Rate-limit, block one domain/tool, isolate one workload	Local policy; optional automatic action at high confidence
High-impact modification	Credential revocation, production configuration change	Explicit tenant approval or independently approved local playbook
Destructive action	Delete data, broad identity revocation, irreversible change	Never directly executable from external intelligence

14.1.3 Organizational and sensor identity

- Each organization controls its own federation identity and issues short-lived identities to its sensors and collectors.
- A central federation root may authorize membership but must not possess keys that allow it to forge an individual organization's observations.
- Sensor assertions bind organization, sensor identity, software version, configuration fingerprint, observation time, evidence commitment, and signature.
- Use mTLS for service authentication and short-lived workload identities inside each trust domain; avoid long-lived bearer credentials wherever practical.

14.1.4 Key hierarchy and role separation

Different cryptographic keys must convey different authorities. Root rotation, software release, intelligence publication, federation checkpoints, and emergency revocation should not share one signing credential.

Key role	Online?	Authority	Recommended protection
Offline root	No	Delegate/rotate subordinate roles and recover trust	Offline HSM or equivalent; multi-person ceremony
Software release	Controlled	Authorize product binaries/images	HSM-backed signing with two-person release approval
Intelligence publisher	Yes/controlled	Sign Agentic Threat Patterns and updates	HSM-backed, short-lived service identity, tightly scoped
Federation checkpoint	Yes	Sign transparency checkpoints	Dedicated isolated key; independently witnessed

Emergency revocation	Mostly offline	Revoke compromised roles and recover	Threshold/multi-party authorization
----------------------	----------------	--------------------------------------	-------------------------------------

High-impact trust changes should use threshold or multi-party approval, for example 2-of-3 or 3-of-5 authorization for root rotation, emergency revocation, release-channel changes, or federation-wide trust recovery.

14.1.5 Software supply-chain security

- Protected branches and mandatory review for security-sensitive code.
- Hardware-backed developer authentication and short-lived CI credentials.
- Hermetic or reproducible builds where practical; build infrastructure isolated from developer workstations.
- Generate SBOM and provenance attestations for every release.
- Sign release artifacts only from dedicated release infrastructure; never from a developer laptop.
- Use TUF-style metadata and version monotonicity to resist rollback, freeze, and mix-and-match attacks.
- Record release artifacts and metadata in the transparency log before broad deployment.

14.1.6 Transparency logs and independent witnesses

A valid signature is insufficient if the signer itself is compromised. Every decision-bearing release should also be committed to an append-only Merkle transparency log. Clients verify inclusion and consistency proofs and compare signed checkpoints with independent witnesses. A split-view attack in which different customers receive conflicting histories for the same log position must trigger an alarm and freeze the affected release channel.

- Operate at least one witness outside the production account boundary.
- Support customer, ISAC, government, or independent nonprofit witnesses for higher-assurance deployments.
- Persist previously observed checkpoints locally so a client cannot be silently rolled back to an older history.

14.1.7 Federation poisoning and false-intelligence resistance

Federation confidence must be based on evidence independence rather than raw report count. Ten sightings produced by the same compromised downstream source should not be treated as ten independent confirmations.

- Track organization, sensor stack, detector version, model family, framework, provider, delivery vector, and evidence method for each sighting.
- Compute an effective corroboration score that discounts correlated sources.
- Require authenticated federation membership; anonymous Sybil participation must not be able to influence enterprise intelligence.
- Distinguish observation from inference, verdict, and recommendation. LLM-generated interpretation is never promoted to observed fact.
- High-impact Agentic Threat Patterns require reproducibility, evidence commitments, and additional review before becoming broadly actionable.

14.1.8 Tenant isolation and blast-radius containment

- Enforce tenant identity at every request boundary and propagate tenant context through storage, queues, caches, and worker jobs.
- Use tenant-scoped database controls and per-tenant or per-cell encryption keys for sensitive evidence.
- For high-assurance customers, support dedicated worker pools, event streams, databases, object-storage namespaces, and KMS keys.
- Partition production into regional/cellular trust domains so compromise of one SaaS cell does not imply compromise of build, release, security logging, research, or government environments.
- Keep research-malware infrastructure in separate cloud accounts/projects with no production credentials or customer data.

14.1.9 Sacrificial adversarial-research infrastructure

The research harness intentionally processes hostile prompts, documents, tools, and potentially malicious software. It must be treated as a hostile execution zone.

- Run experiments in ephemeral VMs or hardened disposable sandboxes, ideally one experiment per environment.
- Do not attach production identities, production networks, or customer datasets to research workers.
- Force egress through controlled proxies and deny direct access to sensitive internal services.
- Destroy workers after experiments and ingest only explicitly collected artifacts into the research datastore.

14.1.10 Security telemetry for BiTorus itself

- Alert on unusual signing operations, key-policy changes, root rotations, mass intelligence publication, anomalous federation submissions, and cross-tenant queries.
- Send privileged audit and security telemetry to an isolated logging/security account that production administrators cannot rewrite.
- Monitor failed signature verification, transparency checkpoint disagreement, unusual export volume, and abnormal administrative access.
- Continuously exercise detection and incident-response runbooks against the BiTorus control plane itself.

14.1.11 Compromise and key-recovery protocol

Compromise recovery must be part of the wire protocol, not an emergency procedure invented after an incident. Clients need explicit revocation and rollback semantics.

- If an online publisher key is compromised, the offline root or emergency-revocation role signs a revocation with an effective time, clients reject later artifacts from the compromised key, and a replacement key is activated.
- If an intelligence release is wrong or malicious, publish a signed retraction or superseding version; active systems roll back operational state while the historical record remains visible.
- If transparency witnesses disagree, freeze the affected release channel until checkpoints are reconciled.
- If the federation control plane is unavailable or suspected compromised, tenant-local detection and policy continue using the last verified intelligence state.

14.1.12 Self-hosted and government trust model

Self-hosted and disconnected deployments should intentionally minimize vendor control. BiTorus supplies signed software and intelligence artifacts; the customer owns operational keys, local data, identity, authorization policy, and activation decisions.

- No permanent BiTorus administrator credential exists inside a self-hosted deployment.
- Support access, when enabled, is customer-initiated, time-limited, narrowly scoped, audited, and automatically expires.
- Air-gapped environments import signed, versioned bundles through the customer's approved transfer process and verify them locally.
- High-assurance customers may require a second local or government approval signature before a BiTorus intelligence bundle becomes active.
- Offline licensing must not contain a phone-home dependency that can disable mission operation.

14.1.13 Security acceptance tests

- Compromise a simulated SaaS service credential and demonstrate that it cannot execute a customer action.
- Compromise one tenant's sensor key and demonstrate that it cannot forge another tenant's assertion.
- Compromise the online intelligence publisher and demonstrate that it cannot sign a software release or replace the offline root.
- Submit many correlated fake sightings and verify that independence scoring prevents false global confidence.
- Serve conflicting transparency histories and verify that witnesses and clients detect the split view.
- Revoke a publisher key and verify deterministic recovery across SaaS, BYOC, self-hosted, and disconnected clients.
- Run the federation unavailable for an extended period and verify safe tenant-local operation.

15. Platform implementation

15.1 Core services

- Edge collector and trace normalizer.
- Model/retrieval gateway integration SDK.
- Capability and policy service.
- Tool execution broker and sandbox manager.
- Memory provenance service.
- Assertion gateway and federation ingress.
- Correlation graph and campaign service.
- Artifact registry and transparency log.
- Tenant control plane and analyst console.

15.2 Recommended implementation stack

Layer	Initial choice
Agent/runtime	Go or Rust; Kubernetes DaemonSet/controller and sidecar/SDK integrations

Policy	OPA/Rego or Cedar-style typed authorization with custom risk obligations
Streaming	Kafka or Redpanda
Transactional state	PostgreSQL
Analytical events	ClickHouse
Object evidence	S3-compatible encrypted storage
Graph	Start with PostgreSQL/ClickHouse derived graph; add dedicated graph store only when required
Identity	SPIFFE/SPIRE-compatible workload identity
Artifacts	OCI registry plus TUF metadata
Observability	OpenTelemetry, Prometheus, and structured security traces

15.3 Deployment models: SaaS, BYOC, self-hosted and disconnected

- Managed SaaS: BiTorus operates the control plane and intelligence services. Customer-local collectors minimize and sign telemetry before sending authorized data.
- BYOC/private data plane: BiTorus manages software lifecycle while sensitive stores, traces, keys and local analytics run in the customer's cloud account or VPC.
- Self-hosted connected: the full control plane, sensor services, graph store, policy distribution, evidence store and user interface run in customer-controlled infrastructure. Outbound-only channels can be used for signed intelligence synchronization.
- Disconnected/air-gapped: core operation requires no routine connection to BiTorus. Intelligence and software updates are distributed as signed, versioned bundles over the customer's approved transfer mechanism.
- Sovereign federation: a government, sector operator or multinational consortium runs its own federation node and decides which threat patterns, evidence commitments and aggregate statistics are exchanged.

15.4 Self-hosted technical requirements

- No dependency on a vendor-hosted database for core operation.
- Customer-managed KMS/HSM and signing roots, with optional offline root keys.
- Private OCI/container registry and signed software bundles.
- Customer-hosted transactional, analytical and object-storage services.
- Local OIDC/SAML/workload-identity integration and customer-defined RBAC.
- Outbound-only or fully offline update modes.
- Exportable signed threat-assertion packages with explicit data-classification labels.
- Backup, disaster recovery and upgrade tooling that does not require vendor administrative access.
- Offline-capable licensing with no phone-home kill dependency.
- Kubernetes-first packaging plus an appliance/VM distribution for environments where Kubernetes is not permitted.

16. Product surfaces and integrations

- Agent SDK for model, retrieval, memory, and tool instrumentation.

- Gateway mode for organizations that cannot modify agent code.
- MCP/tool registration and capability administration.
- Kubernetes operator for isolation and policy enforcement.
- STIX/TAXII import and export.
- SIEM, SOAR, ticketing, repository, CI/CD, identity, and cloud integrations.
- CLI for verification, trace inspection, policy simulation, and incident export.
- Analyst console for causal traces, ATT&CK/ATLAS mapping, and response approval.

17. Reliability, support, and incident operations

- Local policy evaluation continues during federation outages.
- Invalid signatures fail closed for decision-bearing artifacts.
- Expired emergency controls are removed unless renewed.
- Execution receipts are durable and cannot be overwritten by the model.
- Budgets and circuit breakers stop recursive or runaway agents.
- Tenant and regional isolation prevent a federation issue from becoming a customer outage.

Runbook	Required response
Prompt-injection campaign	Contain affected content sources, revoke unsafe policies, distribute indicators and evaluations
Compromised tool or MCP server	Disable registration, revoke capabilities, identify executions, distribute signed block policy
Poisoned memory	Freeze writes, enumerate derived decisions, rollback entries, re-evaluate sessions
Unsafe model release	Stop rollout, revert routing, invalidate assertions tied to affected configuration
Capability broker compromise	Revoke issuer, rotate keys, freeze high-risk execution, verify receipts
False mass quarantine	Global kill switch, automatic rollback, preserve evidence, incident review
Transparency split view	Witness alarm, freeze affected release channel, reconcile checkpoints

18. Security assurance and evaluation

- Direct and indirect prompt injection corpus.
- Retrieval poisoning and malicious document tests.
- Tool-result injection and confused-deputy tests.
- Cross-tenant isolation and secret-exfiltration tests.
- Capability escalation and policy bypass tests.
- Memory poisoning and stale-memory tests.
- Recursive delegation and denial-of-wallet tests.
- Model and provider version regression tests.
- Supply-chain substitution, rollback, and freeze tests.
- Adversarial ML, source-poisoning, and federation Sybil tests.

A model benchmark is not sufficient. The evaluated object is the complete deployed system: model, prompt, retrieval, tools, policy, execution environment, memory, and surrounding identity.

19. Adapted roadmap

Phase	Timing	Primary deliverables	Exit gate
0. Re-charter	0-6 weeks	Threat model, AI use cases, schemas, cryptographic ADRs, design partners	Three partners and external review
1. Vertical prototype	6-16 weeks	Trace SDK, capability broker, signed assertions, Kubernetes response	End-to-end causal trace and safe rollback
2. Private pilot	4-7 months	Multi-tenancy, integrations, ATT&CK/ATLAS correlation, support tooling	Measured risk reduction and acceptable false positives
3. Federation	7-12 months	Independent witnesses, sharing groups, reputation, PSI prototype	Cross-org signal lift without raw telemetry
4. GA	12-18 months	PQC artifact modes, BYOC, managed defense, advanced privacy	Audit closure, SLOs, operational readiness

19.1 Changed prioritization

- Move the capability broker and execution trace into Phase 1; they are foundational, not optional AI add-ons.
- Defer advanced ML until deterministic provenance and policy controls work.
- Add AI-BOM and signed prompt/model/tool release support before federation.
- Add ATLAS and Attack Flow support alongside ATT&CK from the first pilot.
- Make prompt and document privacy a first-class data-governance requirement.
- Evaluate complete agent systems continuously, not only model checkpoints.

20. First 90 days

Days 1-30: architecture and contracts

- Finalize the AI-agent threat model and abuse cases.
- Select two design-partner agent workflows.
- Define execution trace, AI assertion, capability, memory, and receipt schemas.
- Define privacy tiers and fields permitted to leave a tenant.
- Implement signing and transparency-log proof of concept.

- Prototype policy evaluation for typed tool calls.

Days 31-60: vertical implementation

- Build an SDK or gateway integration for one agent framework.
- Instrument model, retrieval, tool, and memory events.
- Build the capability broker with short-lived credentials.
- Integrate Kubernetes workload identity and a constrained execution sandbox.
- Implement prompt-injection and tool-policy detectors.
- Generate signed ATT&CK/ATLAS assertions.

Days 61-90: response and federation demo

- Implement reversible workload and tool isolation.
- Connect two isolated tenant environments.
- Share minimized assertions and correlate one campaign.
- Distribute a signed mitigation and evaluation case.
- Exercise key revocation, bad-rule rollback, poisoned memory rollback, and federation outage.
- Complete external architecture and cryptographic review.

90-day demonstration

A malicious instruction embedded in a retrieved document causes an agent to request a credential-reading tool. BiTorus records the causal trace, denies the capability, maps the sequence to ATLAS and ATT&CK, creates a signed minimized assertion, correlates the same delivery mechanism in a second tenant, distributes a signed retrieval-block and evaluation case, and verifies that both tenants remain locally authoritative.

21. Team and operating model

Role	Pilot staffing
Principal architect / technical lead	1
Distributed systems / backend	2
Kubernetes and agent runtime	2
Applied security / cryptography	1
Detection and threat intelligence	1
AI security / agent systems	1
SRE / platform	1
Product/full-stack	1
Product manager	1
Customer security engineer	1
Fractional privacy counsel and external reviewers	As needed

The AI-security engineer should focus on agent architecture, evaluations, prompt/retrieval threats, and tool control. This is different from a conventional model-training role; the initial product does not require training a large proprietary model.

22. Success metrics

Dimension	Example metric
Coverage	Percentage of agent tool executions with complete causal trace and policy receipt
Prevention	Blocked unauthorized high-risk actions and prompt-injection escape rate
Containment	Time to revoke a capability, tool, model release, or policy across a tenant
Federation value	Incremental detections attributable to independent cross-tenant correlation
Quality	Precision at the operational false-positive budget
Response safety	Rollback success and unintended-action rate
Privacy	Percentage of shared assertions requiring no raw prompt or customer document
Supply chain	Percentage of production AI components represented in signed AI-BOMs
Reliability	Local policy availability and execution-receipt durability
Compromise resilience	No simulated central-service compromise can directly execute an arbitrary tenant action.
Federation integrity	Correlated or Sybil sightings do not materially inflate effective corroboration.
Key recovery	Compromised online signing role can be revoked and replaced within the tested recovery objective.
Transparency	Split-view and rollback attacks are detected by client/witness verification.

23. Risk register

Risk	Mitigation
Customers see the product as another AI firewall	Lead with execution provenance and capability enforcement, not prompt filtering
Instrumentation creates excessive sensitive data	Tenant-local storage, field minimization, commitments, configurable retention
Agent frameworks change rapidly	Stable event schema, gateway mode, adapter SDK, compatibility tests
Policy broker becomes a critical dependency	Local caching, fail-safe modes, high availability, minimal trusted computing base
False positives interrupt operations	Risk classes, dry run, approvals, time-bounded constraints, rollback
Federation is poisoned	Authenticated membership, evidence commitments, independence-aware corroboration, source reputation, challenges, retractions, and rate limits.
Model/provider behavior changes silently	Version binding, regression evaluations, short assertion lifetimes

Advanced cryptography delays delivery	Use minimization first; gate PSI/MPC/FHE behind measured use cases
Security claims exceed evidence	External review, explicit non-goals, measurable pilot gates

24. Architecture decisions

ADR-AI-001: Authorization is external to the model

Models propose actions; deterministic policy and capability services authorize execution.

ADR-AI-002: Capture causal execution traces

The security unit is the complete chain from content origin to external side effect.

ADR-AI-003: Use ATT&CK and ATLAS together

AI incidents often begin in an AI-specific technique and continue as conventional enterprise behavior.

ADR-AI-004: Treat memory as a governed datastore

Memory writes require provenance, namespace isolation, versioning, TTL, and rollback.

ADR-AI-005: Sign all decision-bearing AI artifacts

Models, prompts, tools, policies, evaluations, and routing configurations are release artifacts.

ADR-AI-006: Share minimized AI assertions

Raw prompts and traces remain local unless an explicit disclosure policy authorizes release.

ADR-AI-007: Capability broker is in the launch path

Excessive agency is a fundamental architectural risk, not a later feature.

ADR-AI-008: Evaluate the deployed system

Security evaluation covers model, prompt, retrieval, memory, tools, policy, and execution environment.

ADR-AI-009: No central execution authority

Federation intelligence may recommend or compile mitigations, but local tenant policy remains the final authority for consequential actions.

ADR-AI-010: Role-separated signing hierarchy

Software releases, intelligence publication, federation checkpoints, emergency revocation, and root rotation use distinct cryptographic roles.

ADR-AI-011: Independence-aware corroboration

Federation confidence is derived from evidence diversity and provenance, not the raw count of reports.

ADR-AI-012: Self-hosted customers retain operational sovereignty

Self-hosted and disconnected deployments operate without permanent vendor credentials or phone-home dependencies and retain customer-controlled keys and policy.

Appendix A. Example AI threat assertion

```
{
  "type": "AIThreatAssertion",
  "version": "1.0",
  "assertion_id": "urn:bitorus:assertion:...",
  "tenant_pseudonym": "...",
  "observed_at": "...",
  "system": {
    "agent_id": "...",
    "model_id": "...",
    "model_version": "...",
    "prompt_digest": "...",
    "policy_digest": "...",
    "tool_registry_digest": "..."
  },
  "input": {
    "source_type": "retrieved_document",
    "source_trust": "external_untrusted",
    "content_digest": "..."
  },
  "behavior": {
    "atlas_techniques": [...],
    "attack_techniques": [...],
    "attempted_objective": "credential_access",
    "tool_calls": ["secrets.read"],
    "memory_mutations": []
  },
  "result": {
    "blocked": true,
    "executed": false,
    "side_effects": []
  },
  "evidence": {
    "trace_root": "...",
    "policy_receipt_digest": "..."
  },
  "assessment": {
    "confidence": 0.94,
    "severity": "high",
    "affected_configurations": [...]"
  },
  "lifecycle": {
    "expires_at": "...",
    "sharing_policy": "TLP:AMBER+STRICT"
  },
  "signatures": [...]"
}
```

Appendix B. Example capability policy

```
policy:
  name: agent-production-change
  subject:
    agent_class: deployment-assistant
  action:
    type: kubernetes.patch
```

```

resource:
  cluster: production
  namespace: payments
requirements:
  - signed_plan
  - dry_run_success
  - human_approval
  - change_window_open
constraints:
  allowed_kinds: [Deployment]
  max_replicas_delta: 2
  forbidden_fields:
    - spec.template.spec.serviceAccountName
    - metadata.ownerReferences
  ttl: 15m
obligations:
  - record_execution_receipt
  - create_rollback_patch
  - monitor_for: 10m

```

Appendix C. Initial engineering epics

- Execution trace schema and SDK
- Model and retrieval gateway adapters
- Capability issuer and policy decision service
- Tool execution broker and sandbox
- Memory provenance and rollback
- Kubernetes identity and response controller
- AI assertion gateway and signing
- ATT&CK/ATLAS mapping and attack-flow graph
- Artifact signing, TUF metadata, and transparency log
- Tenant console, incident trace viewer, and approvals
- Evaluation harness and adversarial corpus
- Federation ingress, source reputation, and evidence challenge workflow

References

[R1] BiTorus: A real time, immutable, self learning information security network, Draft v0.1.0, January 1, 2018. User-supplied source document.

[R2] BiTorus 2.0: Federated Cyber Defense Network - Comprehensive Product, Security, and Implementation Design, Version 1.0, August 3, 2026.

[R3] MITRE ATLAS, Adversarial Threat Landscape for Artificial-Intelligence Systems.
<https://atlas.mitre.org/>

[R4] MITRE Center for Threat-Informed Defense, Attack Flow v3. <https://ctid.mitre.org/projects/attack-flow/>

[R5] NIST AI 600-1, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, 2024. <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>

- [R6] OWASP GenAI Security Project, LLM01: Prompt Injection. <https://genai.owasp.org/llmrisk/llm01-prompt-injection/>
- [R7] OWASP GenAI Security Project, Agentic Security Initiative. <https://genai.owasp.org/initiatives/agentic-security-initiative/>
- [R8] MITRE ATT&CK Enterprise. <https://attack.mitre.org/>
- [R9] OASIS STIX 2.1 and TAXII 2.1.
- [R10] CISA Known Exploited Vulnerabilities Catalog and FIRST EPSS.
- [R11] NIST Post-Quantum Cryptography Standards: FIPS 203, 204, and 205.
- [R12] The Update Framework and Sigstore Rekor transparency-log architecture.

25. Market opportunity and commercial strategy

BiTorus should enter the market as Agentic Threat Intelligence and Collective Defense, not as another runtime-governance toolkit. existing enterprise enforcement infrastructure now supplies open-source deterministic tool-call governance, identity, audit, MCP controls, kill switches, and framework adapters. BiTorus should consume runtime enforcement and comparable enforcement systems as sensors and policy targets, then own the intelligence layer above them: attack discovery, causal attack-flow reconstruction, affected-configuration intelligence, portable mitigations, and eventually privacy-minimized cross-enterprise correlation.

25.1 Bottom-up market model

Segment	Organizations	Mature ACV	Annual opportunity
Large enterprise / regulated / government	~20,000	\$300K	\$6.0B
Cloud- and AI-intensive upper mid-market	~60,000	\$100K	\$6.0B
Federation, managed defense, premium services	20% uplift	-	\$2.4B
Planning TAM	-	-	\$14.4B

Planning range: \$10B-\$18B global annual TAM. Initial serviceable market: approximately \$2B-\$4B annually. A credible five-year obtainable target is approximately \$45M-\$90M ARR, with a base case near \$75M ARR. These are internal planning estimates rather than third-party forecasts.

25.2 Ideal customer profile

- 2,000-50,000 employees with production AI agents or coding agents.
- Material use of Kubernetes, public cloud, SaaS APIs, source repositories, CI/CD, and machine identities.
- High-value or regulated data and a security/platform team capable of integrating an execution control plane.
- Priority verticals: financial services, technology/SaaS, healthcare/life sciences, defense/government contractors, professional services, and high-scale commerce.

Likely economic buyers are the CISO, head of cloud/platform security, head of AI security, or infrastructure/platform leadership. Daily users include security operations, detection engineering, AI platform engineering, identity engineering, AppSec, and incident response.

25.3 Commercial wedge

- Prevent coding agents from reading secrets or modifying protected production paths.
- Discover and control MCP servers, agent tools, and non-human identities.
- Prove how untrusted content influenced a proposed action and which policy authorized or denied it.
- Issue task-bound, short-lived credentials rather than standing credentials.
- Detect poisoned retrieval content and persistent memory manipulation.
- Revoke a dangerous tool, model, prompt package, or policy across the fleet.

- Turn confirmed attacks into signed, privacy-minimized intelligence shared with trusted peers.

26. Competitive landscape and positioning

The runtime-governance layer is commoditizing quickly. existing enterprise enforcement infrastructure is MIT-licensed and already provides deterministic policy enforcement, agent identity, auditability, MCP governance, execution controls, and framework adapters. Large vendors and specialist startups are converging on similar local controls. BiTorus should make those products part of its ecosystem rather than enter a feature-for-feature enforcement war.

Competitor/category	Strength	BiTorus response
existing enterprise enforcement infrastructure	MIT-licensed runtime governance, deterministic policy, identity, tool controls, audit, kill switches, and framework adapters.	Integrate with existing runtime enforcement as a sensor and mitigation target; avoid rebuilding commodity controls.
Palo Alto Prisma AIRS	Broad AI gateway/runtime/model security and enterprise distribution.	Deliver cross-vendor intelligence and portable mitigations into Prisma or adjacent controls.
Noma / Zenity / WitnessAI	Agent discovery, posture, access control, runtime monitoring and governance.	Integrate where possible; differentiate on proprietary attack corpus, causal attack graph, and collective-defense data.
HiddenLayer / model security	Model scanning, runtime detection, and research depth.	Focus on agent workflows, tool-use attacks, affected configurations, and mitigation portability.
Recorded Future / Google / CrowdStrike CTI	Large external intelligence corpora and SOC distribution.	Own execution-native agentic intelligence: model/framework/tool susceptibility and reproducible attack patterns.
Internal build / OSS	runtime enforcement, OPA/Cedar, OTel, SPIFFE, gateways and SIEM cover many local controls.	Treat OSS as substrate. Monetize research, normalized attack schema, correlation, exposure intelligence, and network data.

26.1 Category statement

Recommended category: Agentic Threat Intelligence and Collective Defense.

BiTorus discovers how autonomous systems are attacked, reconstructs the causal path from malicious content or compromised components to attempted side effects, determines which models/frameworks/tools/configurations are susceptible, and distributes portable detections, regression tests, and mitigations to trusted participants.

26.2 Defensible differentiation

- Causal attack-flow intelligence: reconstruct how content, retrieval, memory, model decisions, tool calls, identities, and side effects combine into an attack.
- Affected-configuration intelligence: identify which model, framework, MCP server, tool, prompt, policy, and version combinations are susceptible.
- Portable mitigations: compile a verified Agentic Threat Pattern into runtime enforcement, Rego, Cedar, MCP gateway, SIEM, and other enforcement/detection formats.
- Privacy-minimized collective defense with independent sightings, challenges, corrections, revocations, evidence commitments, and transparency witnesses.
- Vendor neutrality: existing enterprise enforcement infrastructure, Noma, Zenity, Prisma, custom runtimes, and future enforcement engines can all become BiTorus sensors and mitigation targets.

27. Pricing, packaging, and payment model

Do not primarily charge per token or per blocked tool call. Monetize proprietary agentic threat research, enterprise exposure matching, local attack-flow analytics, portable mitigation feeds, and later federation membership. Runtime enforcement adapters should remain lightweight and may use open-source components such as existing enterprise enforcement infrastructure.

Package	Annual price	Scope
Paid Design Partner	\$100K-\$175K + \$25K-\$60K implementation	Threat feed + sensor, two production workflows, direct research support, runtime enforcement/runtime integration.
Threat Intelligence Feed	\$75K-\$150K	Agentic Threat Patterns, advisories, affected configurations, regression tests, mitigations, API delivery.
Enterprise Sensor & Exposure	\$150K-\$350K	Local telemetry adapters, attack-flow reconstruction, inventory, exposure matching, SOC integrations.
Enterprise / Private Data Plane	From \$400K	Large deployments, BYOC/private plane, long retention, custom integrations, SLOs and premium support.
Collective Defense Membership	\$100K-\$300K add-on	Cross-org correlation, private sharing groups, evidence challenge, population risk and priority mitigation.
Managed Agentic Threat Research	\$200K-\$750K	Hunting, custom evaluations, detection engineering and incident assistance.

27.1 Contract terms

- Annual subscriptions billed annually in advance, Net 30.
- Quarterly capacity true-up with bounded first-90-day overage protection.
- Implementation billed 50% at signing and 50% at production acceptance.
- Two-year commitment: target ~8% discount; three-year: ~12%.
- Early enterprise ramp example: \$150K -> \$225K -> \$300K over three years.
- Professional services should fall below 10% of total revenue as the product matures.

28. Cost to build and capitalization plan

Cost category	MVP 6-9 month estimate
Engineering and product	\$2.0M-\$2.8M
Cloud/test infrastructure	\$0.2M-\$0.4M
Security/cryptographic review	\$0.15M-\$0.30M
Legal, privacy, insurance	\$0.15M-\$0.30M
Recruiting and operations	\$0.20M-\$0.40M
Contingency	\$0.30M-\$0.50M
Total	\$3.0M-\$4.7M

- Cumulative investment through private pilot (~month 18): \$8M-\$12M with 22-30 people.
- Cumulative investment through production GA (~months 24-30): \$20M-\$30M with 40-55 people.
- Planning capital through sustainable break-even: \$25M-\$35M; slower-sales downside may require \$35M-\$50M.

The dominant post-MVP cost is enterprise reliability, integrations, customer support, audits, sales engineering, incident response, regional infrastructure, and time to establish trust with security buyers.

29. Five-year revenue and profit model

Planning model only: assumes a 6-12 month enterprise sales cycle, increasing ACV with expansion, improving gross margin, and break-even around late Year 4 to Year 5.

Metric	Y1	Y2	Y3	Y4	Y5
Ending customers	6	22	65	145	300
Avg recurring contract	\$110K	\$145K	\$185K	\$225K	\$255K
Ending ARR	\$0.7M	\$3.2M	\$12.0M	\$32.6M	\$76.5M
Total revenue	\$1.1M	\$3.7M	\$11.4M	\$29.0M	\$66.5M
Operating costs	\$5.5M	\$10.0M	\$18.0M	\$30.0M	\$48.0M
Operating profit/(loss)	(\$4.4M)	(\$6.3M)	(\$6.6M)	(\$1.0M)	\$18.5M

Year-five outcome	Downside	Base	Upside
-------------------	----------	------	--------

Customers	150	300	450
Ending ARR	\$28.5M	\$76.5M	\$135M
Revenue	\$27M	\$66.5M	\$110M
Operating result	-\$4M to +\$2M	+\$15M to +\$20M	+\$30M to +\$40M
Capital needed	\$35M-\$50M	\$25M-\$35M	\$20M-\$30M
Break-even	Year 6+	Year 4-5	Year 4

30. Go-to-market plan

- Recruit 5-8 paid design partners; avoid free pilots.
- Require a named executive sponsor and two real production agent workflows.
- Target ~\$100K annual subscription plus \$40K-\$75K implementation for design partners.
- Land with one privileged workflow: coding agent, Kubernetes operator, security investigator, cloud remediator, or sensitive-data research agent.
- Expand through more agents, tools, business units, retention, private data planes, federation and managed defense.
- Target net revenue retention above 115% once mature.

31. Revised product roadmap and funding gates

Stage	Timing	Product objective	Commercial/funding gate
0. Re-charter	0-6 weeks	Threat model, schemas, cryptographic ADRs, two workflows	3-5 qualified design partners.
1. MVP	6-16 weeks	Trace, capability broker, short-lived credentials, K8s/GitHub/cloud integrations	First paid design partners and end-to-end denial/receipt demo.
2. Private pilot	4-9 months	Multi-tenancy, ATT&CK/ATLAS, enterprise integrations, response safety	5-8 paying partners; repeatable deployment.
3. Production	9-18 months	SLOs, compliance, private data plane, AI-BOM, evaluations	~\$1M-\$3M ARR and reference customers.
4. Federation	12-24 months	Private sharing, witnesses, reputation, cross-tenant correlation	Demonstrated intelligence lift.
5. GA expansion	18-30 months	Managed defense, regional scale, advanced privacy/PQC	Repeatable enterprise sales and path to \$10M+ ARR.

31.1 Build-order changes

- Move federation later, but monetize intelligence before federation: Product 1 is a paid Agentic Threat Intelligence feed generated by BiTorus research infrastructure; Product 2 is an enterprise sensor and exposure-matching layer over existing runtimes; Product 3 is the Collective Defense Network once enough customers contribute privacy-minimized observations.
- Do not make a proprietary capability broker the primary moat. Integrate first with existing enterprise enforcement infrastructure, OPA/Cedar, MCP gateways, IAM/PAM systems, and AI-security platforms; build enforcement only where an adapter gap blocks intelligence delivery.
- Do not train a proprietary foundation model for MVP.
- Defer PSI/MPC/FHE until a concrete customer workflow proves minimization and ordinary encryption insufficient.
- Prioritize integrations and enterprise deployment reliability earlier than advanced research features.

32. Updated success metrics and unit economics

Dimension	Metric
Security coverage	>95% of governed tool executions with complete causal trace and policy receipt.
Prevention	Unauthorized high-risk actions prevented; prompt-injection escape rate.
Response	Time to revoke a capability, tool, model release or policy.
Federation value	Incremental detections from independent cross-tenant correlation.
Deployment	Time from contract to first governed production workflow.
Commercial	ACV, win rate, sales cycle, CAC payback, retention and >115% target NRR.
Economics	Long-run software gross margin target ~80%; services <10% of revenue.
Privacy	Most shared assertions require no raw prompt or customer document.

33. Updated business risk register

Risk	Mitigation
Platform bundling	Own the proprietary attack corpus, causal graph, susceptibility matrix, signed intelligence protocol, and cross-vendor mitigation compiler; treat enforcement as an integration surface.
Premature federation	Sell standalone execution security first.
Implementation burden	Opinionated integration paths, SDK/gateway mode and paid custom work.
False blocking	Observe-first rollout, risk classes, approvals, bounded controls and rollback.

Privacy exposure	Tenant-local storage, commitments, selective disclosure and retention controls.
No budget owner	Sell one measurable privileged workflow to one economic owner.
OSS substitution	Compete on integration quality, detections, signed protocol, intelligence network and support.
Long sales cycles	Paid design partners, narrow ICP, annual prepay and milestone-based fundraising.

34. Current market evidence and implications

As of August 2026, Palo Alto Prisma AIRS has expanded into an AI Gateway with centralized visibility and policy enforcement across models, apps and agents. Noma has launched agent access control for AI agents and MCP servers. WitnessAI markets monitoring of agents, MCP servers, tools and shared data. HiddenLayer has expanded runtime security into agentic visibility, investigation, detection and enforcement. Generic agent discovery, prompt filtering and runtime visibility are therefore unlikely to remain differentiated.

BiTorus should treat the proprietary attack graph, Agentic Threat Pattern corpus, model/framework/tool susceptibility data, portable mitigation compiler, evidence-quality system, and privacy-preserving cross-organization intelligence as the core moat. Execution receipts and local authorization remain useful inputs, but are not uniquely defensible.

35. Executive build recommendation

- Agentic Threat Pattern schema and causal attack-graph representation.
- BiTorus adversarial research lab that continuously tests models, frameworks, MCP servers, coding agents, browser agents, and tool configurations.
- existing enterprise enforcement infrastructure as a first-class telemetry and mitigation backend, followed by OPA/Cedar, MCP gateways, SIEM/SOAR, and major AI-security platforms.
- Enterprise sensor that reconstructs local attack flows and matches them against the BiTorus intelligence corpus without requiring raw prompt export.
- Portable mitigation compiler and signed regression-test packages.
- Affected-configuration and exposure intelligence across models, versions, frameworks, tools, prompts, and policies.
- Privacy-minimized Collective Defense Network once 20-50 customers can contribute useful observations.
- Managed Agentic Threat Research and incident-response services after the intelligence product demonstrates pull.

The original BiTorus insight remains intact: a defensive observation made by one participant should rapidly help protect others. The 2026 implementation should accomplish that through authenticated execution evidence, deterministic local authorization, signed intelligence, and controlled federation - not global raw telemetry, permissionless consensus, or token incentives.

36. Research notes for Version 3.0

Market and competitor observations in Sections 25-34 were refreshed in August 2026. Relevant current public evidence includes Palo Alto Networks Prisma AIRS documentation for its July 2026 AI Gateway and agent-security capabilities; Noma Security Agent Access Control for agents and MCP servers (June 2026); WitnessAI Agentic Security (January 2026); HiddenLayer agentic runtime security (March 2026); and contemporary agentic-AI security research. Market-size numbers in this document remain explicit internal planning assumptions because published category estimates overlap materially.

37. Business model: intelligence above enforcement

existing enterprise enforcement infrastructure changes the build-versus-buy decision. runtime enforcement already offers deterministic pre-execution governance, MCP/tool-call inspection, agent identity, auditability, execution controls, and framework adapters. BiTorus should therefore treat local governance as infrastructure and make the proprietary intelligence layer the company.

37.1 Three-product sequence

- Product 1 - Agentic Threat Research & Intelligence. BiTorus operates adversarial research infrastructure that continuously tests major models, agent frameworks, MCP servers, coding agents, browser agents, retrieval paths, memory systems, and tool configurations. Customers pay for early warning before federation exists.
- Product 2 - Enterprise Agent Threat Sensor & Exposure. Lightweight adapters ingest runtime enforcement/runtime/gateway/cloud telemetry, reconstruct local causal attack flows, inventory configurations, and match the customer against the BiTorus corpus. Raw prompts and traces stay local by default.
- Product 3 - Collective Defense Network. After roughly 20-50 customers, participants may contribute privacy-minimized observations. BiTorus correlates independent sightings, estimates population risk, identifies newly affected configurations, and pushes verified mitigations.

37.2 Core proprietary object: Agentic Threat Pattern

Each Agentic Threat Pattern should encode attack family, behavior graph, delivery vector, influence path, affected models/frameworks/tools/versions, exploit prerequisites, observed success rate, ATT&CK/ATLAS mappings, reproduction harness, detection, mitigation, false-positive measurements, evidence commitments, independent sightings, confidence, lifecycle, and signatures.

37.3 Why customers pay before network effects

The first revenue does not depend on federation. BiTorus can create proprietary intelligence through its own research lab and sell emerging attack advisories, susceptibility matching, regression tests, and portable mitigations. Customer telemetry then improves validation and coverage. Federation becomes a compounding moat rather than a prerequisite for product-market fit.

38. Revised commercial model

- Design Partner: \$100K-\$175K ARR plus \$25K-\$60K implementation. Includes threat feed, enterprise sensor, two production workflows, and direct research support.
- Agentic Threat Intelligence Feed: \$75K-\$150K ARR.
- Enterprise Sensor & Exposure: \$150K-\$350K ARR.
- Enterprise / Private Data Plane: from \$400K ARR.
- Collective Defense Membership: \$100K-\$300K ARR add-on once network density is sufficient.
- Managed Agentic Threat Research: \$200K-\$750K ARR or retainer.

Subscriptions should be annual and prepaid, with multi-year discounts. Do not price the core product primarily per token or blocked tool call. The customer is buying intelligence freshness, exposure coverage, attack-flow analytics, mitigation quality, and eventually network intelligence.

38.1 Subscription architecture

BiTorus should separate the subscription into three economic layers: intelligence, local platform coverage, and network/federation services. This lets a customer buy useful intelligence before contributing any data to the network.

The intelligence entitlement is organization-wide and covers the continuously updated Agentic Threat Pattern corpus, advisories, affected-configuration matrix, detection content, regression tests, mitigation packages, and API/feed access.

The platform entitlement covers protected environments: agent runtimes, gateways, clusters, cloud accounts, and local attack-flow analysis. Capacity can be measured using bands of active protected agents and governed tool actions, but should be sold in predictable annual tiers rather than per-token metering.

The Collective Defense entitlement is a premium add-on providing cross-participant correlation, private sharing groups, independent-sighting confidence, priority emerging-campaign alerts, and sector-specific intelligence. Participation never requires sharing raw prompts or full traces.

38.2 Recommended subscription packages

Package	Annual price	Best fit	Included	Deployment
Intelligence	\$75K-\$150K	Security research / SOC	Threat feed, affected configurations, tests, portable detections and mitigations, API	Cloud feed or offline signed bundles
Enterprise Sensor	\$150K-\$350K	Production agent deployments	Intelligence + local attack graph, exposure matching, integrations, dashboards	SaaS, BYOC or self-hosted
Enterprise Private	\$350K-\$750K+	Regulated/high-sensitivity enterprises	Private data plane, advanced retention, custom integrations, premium support	BYOC or self-hosted
Collective Defense	\$100K-\$300K add-on	Cross-network early warning	Independent sightings, sector groups, cross-org campaign correlation, priority alerts	All deployment modes

Government / Mission	\$500K-\$2M+	Federal, defense, intelligence, critical infrastructure	Self-hosted/disconnected operation, mission feeds, sovereign support, enclave/facility licensing	On-prem, private cloud, disconnected/air-gapped
----------------------	--------------	---	--	---

Recommended contract mechanics:

- Annual prepaid subscription; Net 30 for standard commercial customers and procurement-compatible payment terms for public-sector customers.
- Two-year commitment: approximately 8% discount; three-year commitment: approximately 12% discount.
- Capacity true-up quarterly or annually with a usage buffer rather than surprise overage billing.
- Implementation is separate: typically \$25K-\$60K commercial and \$75K-\$250K for complex self-hosted or government deployments.
- Intelligence-only customers can upgrade to the enterprise sensor without changing the feed contract.
- Disconnected customers receive signed intelligence bundles on a scheduled cadence with emergency out-of-band releases when necessary.

39. Revised build cost and capitalization

The pivot reduces the amount of undifferentiated runtime infrastructure BiTorus must build, but requires a stronger research organization. A credible design-partner MVP can be built with roughly 10-13 people: 4-5 platform/integration engineers, 2-3 security researchers, one applied cryptography/security engineer, one detection/intelligence engineer, one product/full-stack engineer, and founder/product leadership.

- Design-partner MVP (9-12 months): approximately \$3M-\$5M.
- Private pilot and repeatable sensor/integration product (through ~18 months): cumulative \$8M-\$12M.
- Collective-defense launch and enterprise scale (through ~30 months): cumulative \$18M-\$28M.
- Planning capital through sustainable break-even: approximately \$25M-\$35M; slower enterprise sales can push this toward \$40M+.

40. Revised five-year revenue model

Year	Customers	Revenue	Primary driver
Year 1	6-10	\$1M-\$1.8M	Paid research + design partners
Year 2	20-30	\$4M-\$6M	Threat feed + repeatable enterprise sensor
Year 3	60-80	\$12M-\$18M	Collective Defense Network launches

Year 4	140-180	\$30M-\$42M	Federation and managed research expand ACV
Year 5	275-350	\$65M-\$90M	Target 15%-25% operating margin

This is a planning model, not a forecast. The main sensitivity is enterprise sales velocity and whether customers value proprietary agentic threat research enough to buy before the federation network reaches scale.

41. Revised go-to-market

- Recruit 5-8 paid design partners with production agents and a named security or platform executive sponsor.
- Land with one high-risk workflow: coding agent, cloud/Kubernetes operator, security investigator, browser agent, or agent with sensitive SaaS access.
- Make existing enterprise enforcement infrastructure a first-class integration and publish an adapter that converts runtime enforcement audit/governance events into the BiTorus causal schema.
- Ship threat advisories and regression tests continuously so customers receive value even when no local incident occurs.
- Use anonymized outcome metrics to prove time-to-detection, susceptibility discovery, and mitigation portability.
- Launch federation only when enough independent contributors exist to improve intelligence quality.

41.1 Government and national-security market

Government use should be designed as a sovereign early-warning network for autonomous systems, cyber operations, critical infrastructure, and mission environments. Agencies can operate BiTorus locally inside protected enclaves while receiving signed external intelligence and selectively contributing sanitized observations to a trusted government or allied federation.

- Federal civilian agencies: protect internal AI agents, cloud automation, citizen-service systems, procurement workflows and privileged administrative tools; correlate threats across departments without collapsing agency data boundaries.
- Defense organizations: operate BiTorus inside mission enclaves to detect poisoned mission data, compromised autonomous workflows, tool-use abuse and AI-enabled cyber activity. Intelligence can move between enclaves through approved cross-domain or offline transfer processes.
- Intelligence organizations: use causal attack graphs and evidence commitments to correlate weak signals across compartmented environments while retaining raw-source custody locally.
- Critical infrastructure and sector regulators: operate sector-specific early-warning networks for energy, transportation, communications, healthcare and financial infrastructure, analogous to distributed tsunami and undersea sensor networks.
- State and local governments: consume a managed government edition or shared service, gaining national intelligence without operating the full research infrastructure.
- Allied governments: run sovereign national nodes that exchange selected signed threat patterns with a multinational trust group while preserving national control of sensitive telemetry.

41.2 Government deployment and compliance strategy

- Federal cloud service offerings should account for the applicable FedRAMP authorization path. The product architecture should make cloud and self-hosted editions separable so customers can adopt intelligence before a hosted authorization is complete.
- DoD cloud deployments should account for the DoD Cloud Computing Security Requirements Guide and the security requirements applicable to the mission and data.
- Defense-industrial-base deployments that process Controlled Unclassified Information should be designed to support customers operating under NIST SP 800-171 and CMMC-related obligations.
- The self-hosted edition should run without inbound Internet dependencies and support customer-controlled keys, private registries, local identity, local observability and signed offline intelligence updates.
- Government contracts should support agency-wide, department-wide, enclave/facility and national/sector-federation licensing rather than only per-agent subscriptions.

41.3 Illustrative government pricing

Offering	Illustrative annual price	Scope	Commercial logic
Agency Intelligence	\$250K-\$750K	Agency-wide threat feed and offline bundle rights	Low-friction entry; useful before broad deployment
Mission Enclave	\$500K-\$1.5M	One sensitive enclave or mission environment	Self-hosted, local evidence, mission integrations
Department / Enterprise	\$1.5M-\$5M+	Multiple enclaves, regions, agencies or commands	Volume licensing, private federation, premium support
National / Sector Federation	\$3M-\$10M+	Shared early-warning network across agencies or critical-infrastructure members	Federation governance, sector research, sovereign operation and custom support

42. Defensibility and long-term moat

The durable moat is not the policy engine. It is the continuously refreshed attack corpus, normalized causal graph, susceptibility matrix across models/frameworks/tools/configurations, portable mitigation compiler, independent-sighting dataset, and trusted exchange protocol. If Microsoft, AWS, Google, Palo Alto, Noma, Zenity, and others all improve local enforcement, BiTorus should become more valuable because it can ingest more standardized evidence and distribute intelligence into more enforcement points.

Success requires avoiding a two-year federation waiting period. The company must be able to sell proprietary research and enterprise exposure intelligence in year one; the network effect then improves an already useful product.

43. Immediate 180-day execution plan

- Month 0-1: freeze the Agentic Threat Pattern schema, causal graph, evidence model, and privacy tiers.
- Month 1-2: build existing enterprise enforcement infrastructure ingestion and mitigation adapters plus one generic OpenTelemetry/MCP adapter.
- Month 1-3: stand up the adversarial research harness for major model/framework/tool combinations.
- Month 2-4: launch the first intelligence feed with reproducible attack cases, affected configurations, and regression tests.
- Month 3-5: deploy the enterprise sensor with 2-3 paid design partners; keep raw evidence tenant-local.
- Month 4-6: add portable policy compilation, exposure dashboard, independent-sighting logic, and the first private sharing group.
- Gate federation expansion on measurable signal lift from cross-customer observations.